



Weekly IT Security Brief (Official-source-first) | 2026-07-26 06:00

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-16232(2026-07-25), CVE-2026-50522(2026-07-25), CVE-2026-60137(2026-08-04). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Email threat landscape: Q2 2026 trends and insights. In the second quarter of 2026, the continuing effects of Microsoft's disruption of the Tycoon2FA phishing platform contributed to sustained declines in several major phishing techniques, wh...
- Threat trend #2: Real world incident response: Microsoft and AXA XL strengthen cyber resilience. Our collaboration with AXA XL brings Microsoft Incident Response services directly to cyber insurance policyholders, helping organizations coordinate technical, b...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-16232

CVE Title	CVE-2026-16232 checkpoint/multi-domain_security_management Auth Bypass
CVE Description	An authentication bypass vulnerability in the Check Point SmartConsole login process allows an unauthenticated remote attacker to obtain an application login token and use it to authenticate with full administrative privileges. Successful exploitation allows the attacker to modify security policies and security configurations. Remote exploitation requires internet access to the Management Server IP address and a con...
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	checkpoint/multi-domain_security_management, checkpoint/quantum_security_management
Risk Score	9.1 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-25
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-16232

CVE-2026-50522

CVE Title	CVE-2026-50522 microsoft/sharepoint_server Deserialization
CVE Description	Deserialization of untrusted data in Microsoft Office SharePoint allows an unauthorized attacker to execute code over a network.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/sharepoint_server
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-25
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-50522

CVE-2026-60137

CVE Title	CVE-2026-60137 wordpress/wordpress SQL Injection
CVE Description	WordPress 6.8.x before 6.8.6, 6.9.x before 6.9.5, and 7.0.x before 7.0.2 does not properly sanitise the author__not_in parameter of WP_Query, which could allow SQL Injection when a plugin or theme passes untrusted input to the parameter.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	wordpress/wordpress
Risk Score	5.9 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-08-04
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-60137

CVE-2026-63030

CVE Title	CVE-2026-63030 wordpress/wordpress Remote Code Execution
CVE Description	WordPress 6.9.x before 6.9.5 and 7.0.x before 7.0.2 is affected by a REST API batch endpoint route confusion issue which, combined with the author__not_in WP_Query SQL Injection (CVE-2026-60137), could allow an attacker to perform SQL Injection and achieve Remote Code Execution.
Root Cause	Unsafe deserialization or input-handling flaws enable arbitrary code execution.
Exploitation Prerequisite	Relevant endpoint is exposed and unpatched.
Exploit Path	Malicious request/payload -> vulnerability trigger -> remote command execution.
Affected Products	wordpress/wordpress
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-24
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-63030

CVE-2026-0770

CVE Title	CVE-2026-0770 langflow/langflow Remote Code Execution
CVE Description	Langflow exec_globals Inclusion of Functionality from Untrusted Control Sphere Remote Code Execution Vulnerability. This vulnerability allows remote attackers to execute arbitrary code on affected installations of Langflow. Authentication is not required to exploit this vulnerability.
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	langflow/langflow
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-24
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-0770



Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-16156

CVE Title	CVE-2026-16156 待核實 XSS
CVE Description	A security flaw has been discovered in SourceCodester Class and Exam Timetabling System 1.0. This affects an unknown part of the file /forexam.php. The manipulation of the argument day results in cross site scripting. It is possible to launch the attack remotely. The exploit has been released to the public and may be used for attacks.
Affected Products	待核實
Risk Score	3.5 (LOW)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-16156

CVE-2026-16194

CVE Title	CVE-2026-16194 待核實 SSRF
CVE Description	A vulnerability was determined in zhayujie CowAgent up to 2.1.1. This affects the function WebFetch.execute of the file agent/tools/web_fetch/web_fetch.py. Executing a manipulation of the argument url can lead to server-side request forgery. The attack may be performed from remote. The exploit has been publicly disclosed and may be utilized. Upgrading to version 2.1.2 is able to mitigate this issue. This patch is ca...
Affected Products	待核實
Risk Score	6.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-16194

CVE-2026-10130

CVE Title CVE-2026-10130 | 待核實 | Auth Bypass

CVE Description QueryWeaver contains an authentication bypass vulnerability that allows unauthenticated attackers to obtain valid session tokens for existing accounts by submitting a signup request with a known victim email address. The signup route unconditionally creates and links a new token to the matching Identity via a Cypher MERGE operation before checking whether the email belongs to an existing account, causing the server...

Affected Products 待核實

Risk Score 8.2 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-10130>

CVE-2026-16195

CVE Title CVE-2026-16195 | 待核實 | Unknown Type

CVE Description A security flaw has been discovered in Sipeed PicoClaw up to 0.2.9. This issue affects the function dispatchIncoming of the file pkg/channels/wecom/wecom.go of the component Group Message Handler. The manipulation results in incorrect authorization. It is possible to launch the attack remotely. The exploit has been released to the public and may be used for attacks. The reported GitHub issue was closed automatically...

Affected Products 待核實

Risk Score 6.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-16195>



Report B: Threat Intelligence News (last 7 days)

Headline: Email threat landscape: Q2 2026 trends and insights

Source	Microsoft Security Blog
Published	Thu, 23 Jul 2026 15:00:00 +0000
Key Takeaway	In the second quarter of 2026, the continuing effects of Microsoft's disruption of the Tycoon2FA phishing platform contributed to sustained declines in several major phishing techniques, while threat actors expanded into Teams-based social engineering and employed increasingly automated and multi-st Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	Social Engineering
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/07/23/email-threat-landscape-q2-2026-trends-and-insights/

Headline: Real world incident response: Microsoft and AXA XL strengthen cyber resilience

Source	Microsoft Security Blog
Published	Wed, 22 Jul 2026 16:00:00 +0000
Key Takeaway	Our collaboration with AXA XL brings Microsoft Incident Response services directly to cyber insurance policyholders, helping organizations coordinate technical, business, and insurance decisions. The post Real world incident response: Microsoft and AXA XL strengthen cyber resilience appeared first o Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/07/22/real-world-incident-response-microsoft-and-axa-xl-strengthen-cyber-resilience/

Headline: CISA, NSA, FBI and Partners Warn Zimbra Collaboration Suite Users of Ongoing Russian State-Supported Malicious Threat Activity

Source	CISA News
Published	Thu, 23 Jul 26 12:00:00 +0000
Key Takeaway	CISA, NSA, FBI and Partners Warn Zimbra Collaboration Suite Users of Ongoing Russian State-Supported Malicious Threat Activity Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-nsa-fbi-and-partners-warn-zimbra-collaboration-suite-users-ongoing-russian-state-supported

Headline: CISA, FBI, EPA and U.S. Government Partners Update Warning of Iran-Affiliated Threat Actors Targeting Critical Infrastructure Programmable...

Source CISA News

Published Wed, 22 Jul 26 12:00:00 +0000

Key Takeaway CISA, FBI, EPA and U.S. Government Partners Update Warning of Iran-Affiliated Threat Actors Targeting Critical Infrastructure Programmable Logic Controllers Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target government/待核實

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.cisa.gov/news-events/news/cisa-fbi-epa-and-us-government-partners-update-warning-iran-affiliated-threat-actors-targeting>

Headline: Don't swing at everything

Source Cisco Talos Blog

Published Thu, 23 Jul 2026 18:00:46 GMT

Key Takeaway Thorsten explores Q2 2026 stats, the artificial buffer zone of 2026, and why smart, prioritized patching is more critical than ever.
Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/dont-swing-at-everything/>

Headline: Chaos ransomware's msaRAT: Living off the browser to build a covert C2 channel

Source	Cisco Talos Blog
Published	Thu, 23 Jul 2026 10:00:38 GMT
Key Takeaway	The Chaos ransomware group uses new malware "msaRAT" that hijacks browsers. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/chaos-msarat-living-off-the-browser-to-build-covert-c2-channel/

Headline: Malvertising Sends Malware in Pieces, Then Makes the Browser Build the Executable

Source	The Hacker News
Published	Sun, 26 Jul 2026 00:18:44 +0530
Key Takeaway	A malvertising operation dubbed SourTrade is making victims' browsers build the final Windows executable themselves, using a legitimate Bun runtime as its base instead of serving one complete malicious file from a fixed URL. Confiant, which detailed the campaign on July 23, 2026, said it has operate Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/laterna...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/07/malvertising-sends-malware-in-pieces.html

Headline: Fastjson 1.x RCE Vulnerability Targeted in Attacks With No Patched Available

Source	The Hacker News
Published	Sat, 25 Jul 2026 18:22:43 +0530
Key Takeaway	Tracked as CVE-2026-16723, the vulnerability carries an Alibaba-assigned CVSS score of 9.0. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	CVE exploitation
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-16723
Link	https://thehackernews.com/2026/07/fastjson-1x-rce-vulnerability-targeted.html

Headline: Rockwell Patches Code Execution Flaws in Arena Simulation Software

Source	SecurityWeek
Published	Sat, 25 Jul 2026 08:30:00 +0000
Key Takeaway	A researcher has explained how an attacker could exploit these vulnerabilities to target industrial organizations. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	industrial/待核實
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/rockwell-patches-code-execution-flaws-in-arena-simulation-software/

Headline: In Other News: Dolphin X AI-Powered Malware, Car Anti-Theft Device Hack, 400 Linux Kernel Flaws

Source	SecurityWeek
Published	Fri, 24 Jul 2026 14:20:00 +0000
Key Takeaway	Noteworthy stories that might have slipped under the radar: Siemens ROX II industrial switch vulnerabilities, Russian Zimbra webmail espionage campaign, Stadler Rail ransomware extortion attempt. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	industrial/待核實
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-dolphin-x-ai-powered-malware-car-anti-theft-device-hack-400-linux-kernel-flaws/

Headline: Malicious sites use JavaScript to build malware in browser memory

Source BleepingComputer

Published Sat, 25 Jul 2026 11:21:09 -0400

Key Takeaway A massive malvertising campaign is using fake Solana, Luno, and TradingView webpages with malicious JavaScript that instructs browsers to assemble malware directly in memory. [...] Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique Malware Deployment

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/malicious-sites-use-javascript-to-build-malware-in-browser-memory/>

Headline: ShinyHunters data leaks fuel \$2,000 sextortion email scam

Source BleepingComputer

Published Sat, 25 Jul 2026 10:16:26 -0400

Key Takeaway Threat actors are using email addresses exposed in data breaches leaked by the ShinyHunters extortion group to send sextortion emails demanding \$2,000 in Bitcoin. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/shinyhunters-data-leaks-fuel-2-000-sextortion-email-scam/>



Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

<https://attack.mitre.org/>

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)